

Business Requirement Document

User Registration & Login Module

ShopSphere E-Commerce Platform — Platform Modernization Program (FY2026)

Document Title	Business Requirement Document — User Registration & Login Module
Document ID	BRD-EC-UAL-001
Version	1.0
Author	Vikram Singh, Senior Business Analyst
Date	12-Jan-2026
Status	Approved

1. Document Information

Program	ShopSphere Platform Modernization Program (FY2026)
Module	User Registration & Login
Platform	ShopSphere E-Commerce Platform (Web + Mobile App), ~2 million MAU, operating in India, UAE, and Southeast Asia
Prepared For	ShopSphere Product, Engineering, QA, and Compliance teams
Distribution	Executive Sponsor, Product Owner, IT Architecture, QA, UX, DevOps, Compliance & Security

2. Executive Summary

The User Registration & Login Module is the foundational identity gateway of the ShopSphere E-Commerce Platform, governing how new and returning customers establish and access their accounts across web and mobile channels. As part of the ShopSphere Platform Modernization Program for fiscal year 2026, this module is being redesigned to reduce registration drop-off, strengthen account security against credential stuffing and bot-driven fraud, and deliver a frictionless, consistent authentication experience across India, UAE, and Southeast Asia. Current-state analysis indicates that a meaningful share of prospective customers abandon registration due to excessive form fields, unreliable OTP delivery, and a lack of social login options, while account takeover attempts have risen in line with platform growth to approximately 2 million monthly active users. This document defines the business, functional, and non-functional requirements necessary to deliver a modern registration and login experience — including email and mobile+OTP self-registration, Google and Facebook social login, secure password management, risk-based multi-factor step-up authentication, and seamless linking of guest checkout activity to registered accounts — while maintaining compliance with regional data protection expectations and the company-wide security baseline (OWASP Top 10, PCI-DSS scope boundaries, AES-256 at rest, TLS 1.2+ in transit).

3. Business Objective

The primary business objective of this module is to maximize the conversion of visitors into registered, retained customers by removing friction from account creation and sign-in, while simultaneously protecting customer accounts and platform integrity from fraud and unauthorized access. Specific objectives include: (a) reducing registration abandonment rate by at least 20% relative to the current baseline; (b) increasing the proportion of sessions authenticated via low-friction methods (social login, OTP) to reduce reliance on remembered passwords; (c) reducing account takeover incidents through rate limiting, lockout policies, and risk-based multi-factor authentication; (d) improving customer lifetime value by capturing accurate, lightweight profile data at the point of signup for downstream personalization in Salesforce CRM; and (e) ensuring the registration and login experience scales reliably during peak sale events such as Diwali and Black Friday, when new-user sign-up volume can spike to several multiples of normal-day traffic.

4. Project Scope

In Scope

- Self-registration via email address with verification link, and via mobile number with OTP verification.

- Social login and registration via Google and Facebook OAuth providers.
- Standard username/email + password login for returning customers.
- Forgot password and reset password flows via email link and SMS OTP.
- Session management, including session timeout, "remember this device," and concurrent session handling.
- Account lockout and cool-down enforcement after repeated failed login attempts.
- Lightweight profile capture at signup (name, email or mobile, preferred language, marketing consent).
- Guest-to-registered account linking, allowing guest checkout order history to be associated with a newly created account.
- Risk-based step-up authentication (additional OTP challenge) for logins flagged as high risk.

Out of Scope

- Full KYC/AML identity verification (applicable to seller onboarding and regulated payment instruments, covered under separate BRDs).
- B2B/corporate account provisioning and multi-user business account hierarchies.
- Internal admin single sign-on, which is covered by the Admin Dashboard BRD.
- Loyalty program enrollment and loyalty points ledger management.

5. Stakeholders

Name	Role	Department	Responsibility
Rajesh Mehta	VP of E-Commerce	Business	Executive Sponsor
Ananya Sharma	Product Owner, ShopSphere Platform	Product	Prioritization & sign-off
Vikram Singh	Senior Business Analyst	Business Analysis	Requirements owner
Sarah Chen	Enterprise IT Architect	IT/Architecture	Technical feasibility
Michael Torres	QA Lead	Quality Assurance	Test strategy & sign-off
Priya Nair	UX Lead	Design	User experience
David Kim	DevOps Lead	Engineering/Infra	Deployment & monitoring
Fatima Al-Sayed	Compliance & Security Officer	Risk & Compliance	Regulatory compliance

6. Business Requirements

ID	Business Requirement
BR-001	The platform shall enable prospective customers to create an account through multiple, low-friction channels (email, mobile+OTP, and social login) to minimize registration abandonment.
BR-002	The platform shall enforce secure password and account access policies that protect customer PII and reduce the incidence of account takeover.
BR-003	The platform shall allow returning customers to authenticate quickly and reliably across web and mobile app channels with a consistent experience.
BR-004	The platform shall provide a self-service account recovery mechanism so that customers who forget their password or lose access to a device are not permanently locked out.
BR-005	The platform shall capture sufficient customer profile information at registration to support personalization, order communication, and Salesforce CRM Customer 360 records without over-burdening the signup form.
BR-006	The platform shall detect and mitigate automated bot registrations and credential stuffing attacks to protect platform integrity and GMV.
BR-007	The platform shall allow guests who checked out without an account to seamlessly convert to registered customers, preserving their order and cart history.
BR-008	The platform shall support registration and login volumes at up to 10x normal traffic during peak sale events without service degradation.

7. Functional Requirements

7.1 Registration

- **FR-001** The system shall allow a user to register using a valid email address and a password meeting the defined complexity policy, sending a verification link via the SendGrid Email API.

- **FR-002** The system shall allow a user to register using a mobile number, sending a 6-digit One-Time Password (OTP) via the Twilio SMS Gateway, valid for 10 minutes.
- **FR-003** The system shall allow a user to register or log in using Google or Facebook OAuth 2.0, automatically pre-populating name and email from the provider profile.
- **FR-004** The system shall capture, at minimum, full name, email or mobile number, preferred language, and marketing consent during registration, deferring optional fields (date of birth, gender, delivery address) to a post-signup profile completion prompt.
- **FR-005** The system shall create or update a corresponding customer record in Salesforce CRM upon successful registration, including consent flags and account source channel.
- **FR-006** The system shall screen new registrations through the Signifyd Fraud Detection Service and flag or block accounts exhibiting bot-like or high-risk signup patterns.

7.2 Login & Session Management

- **FR-007** The system shall allow login via registered email/mobile and password, or via linked social login provider.
- **FR-008** The system shall issue a secure session token upon successful login, valid for a configurable duration (default 30 days on mobile app with "remember me," 24 hours on web without it).
- **FR-009** The system shall apply risk-based step-up authentication, prompting an additional OTP challenge when login is attempted from a new device, new geolocation, or after a password reset.
- **FR-010** The system shall allow a user to view and revoke active sessions/devices from an account security settings page.

7.3 Account Recovery & Lockout

- **FR-011** The system shall provide a "Forgot Password" flow that sends a time-limited (30-minute) reset link via email or an OTP via SMS, based on the account's registered contact method.
- **FR-012** The system shall lock an account for 15 minutes after 5 consecutive failed login attempts within a 10-minute window, notifying the customer via email of the lockout event.
- **FR-013** The system shall require re-verification of identity (OTP or security question) before allowing a password reset on a previously locked or flagged account.

7.4 Guest-to-Registered Linking

- **FR-014** The system shall detect when a guest checkout email or mobile number matches a newly registered account and offer to link prior guest order history to the new account.
- **FR-015** The system shall send a welcome notification (email and push via Firebase Cloud Messaging) upon successful registration confirming account creation and any linked order history.

8. Non-Functional Requirements

Performance

- **NFR-001** Registration and login API responses shall complete within 2 seconds at the 95th percentile under normal load.
- **NFR-002** OTP delivery via Twilio SMS Gateway shall be initiated within 5 seconds of request submission for at least 99% of requests.

Security

- **NFR-003** The module shall comply with OWASP Top 10 controls, with mandatory penetration testing prior to each major release.
- **NFR-004** Passwords shall be hashed using bcrypt (or equivalent) with a minimum cost factor of 12; no plaintext password shall ever be stored or logged.
- **NFR-005** All PII shall be encrypted using AES-256 at rest and transmitted exclusively over TLS 1.2 or higher.
- **NFR-006** Login and registration endpoints shall enforce rate limiting (max 10 requests per minute per IP) to mitigate credential stuffing and bot attacks.

Availability

- **NFR-007** The registration and login services shall maintain 99.9% uptime for customer-facing endpoints, measured monthly.
- **NFR-008** Planned maintenance windows shall not overlap with declared peak sale event periods.

Scalability

- **NFR-009** The module shall auto-scale to support up to 10x normal registration/login traffic during peak events such as Diwali and Black Friday without manual intervention.
- **NFR-010** OTP and email verification queues shall be horizontally scalable to prevent delivery backlogs during traffic spikes.

Reliability

- **NFR-011** The module shall meet a Recovery Point Objective (RPO) of 15 minutes and Recovery Time Objective (RTO) of 1 hour for identity data.
- **NFR-012** Failed OTP or email delivery attempts shall automatically retry up to 3 times via alternate provider routing before surfacing an error to the user.

9. User Stories

- **US-001** As a new customer, I want to register using just my mobile number and an OTP, so that I can create an account quickly without filling out a long form.
- **US-002** As a returning customer, I want to log in with my Google account, so that I don't have to remember another password.
- **US-003** As a customer who forgot my password, I want to reset it using a link sent to my email, so that I can regain access to my account without contacting support.
- **US-004** As a security-conscious customer, I want to be notified and challenged with an extra verification step when someone tries to log in from an unrecognized device, so that my account stays protected.
- **US-005** As a guest shopper, I want my previous guest orders to automatically appear in my account after I register with the same email, so that I have a complete order history.
- **US-006** As a customer, I want to see and manage the list of devices currently logged into my account, so that I can revoke access if I no longer recognize a session.
- **US-007** As a Product Owner, I want visibility into registration funnel drop-off points, so that I can prioritize UX improvements that increase conversion.
- **US-008** As a Compliance Officer, I want all registration and login events logged with timestamps and outcomes, so that I can support audit and fraud investigations.

10. Acceptance Criteria

AC ID	Related ID	Criteria	Expected Result
AC-001	FR-001	Given a valid unused email, when a user submits registration with a compliant password, then a verification email is sent within 30 seconds.	Account created in "pending verification" state
AC-002	FR-002	Given a valid mobile number, when a user requests OTP registration, then a 6-digit OTP is delivered via Twilio within 5 seconds.	OTP received and account created upon correct entry
AC-003	FR-003	Given a user selects "Continue with Google," when OAuth consent is granted, then the account is created or matched using the Google-verified email.	User is logged in without additional password step
AC-004	FR-009	Given a login attempt from a new device/location, when credentials are valid, then the system prompts for an OTP step-up challenge.	Login completes only after OTP is verified
AC-005	FR-012	Given 5 consecutive failed login attempts within 10 minutes, when the 5th attempt fails, then the account is locked for 15 minutes.	Lockout email sent; further attempts rejected during lockout
AC-006	FR-011	Given a user requests password reset, when the reset link is used within 30 minutes, then the user can set a new compliant password.	Old password invalidated; new password active immediately
AC-007	FR-014	Given a guest order exists under an email, when the same email is used to register, then prior orders are linked to the new account.	Order history visible in "My Orders" post-registration
AC-008	NFR-006	Given more than 10 login requests per minute from a single IP, when the threshold is exceeded, then subsequent requests are throttled.	HTTP 429 response with retry-after guidance
AC-009	FR-010	Given a logged-in user views account security settings, when they select "revoke session" on a device, then that device's session token is invalidated immediately.	Revoked device is logged out on next request

11. Business Rules

- **RULE-001** Passwords must be a minimum of 8 characters and include at least one uppercase letter, one lowercase letter, one number, and one special character.
- **RULE-002** An email address or mobile number may be associated with only one active registered account at a time.
- **RULE-003** OTPs are valid for a single use and expire after 10 minutes; a maximum of 5 OTP requests are allowed per contact method per hour.
- **RULE-004** Marketing communication consent captured at registration must be explicit (opt-in), not pre-checked, in compliance with regional data protection expectations.
- **RULE-005** Accounts flagged as high-risk by the Signifyd Fraud Detection Service shall be placed under manual review before full activation.
- **RULE-006** A locked account may only be unlocked through successful identity re-verification or after the 15-minute automatic cool-down period elapses.
- **RULE-007** Social login accounts must still capture a verified email or mobile number before checkout can be completed, to enable order communication.

12. Process Flow Description

Primary Flow — New Customer Registration and First Login:

1. Customer navigates to the registration page on web or mobile app and selects a registration method: email, mobile+OTP, or social login.
2. Customer enters required details (email/mobile, password, or OAuth consent) and submits the form.
3. System validates input format, checks for duplicate accounts, and screens the request through the Signifyd Fraud Detection Service.
4. System sends a verification email (via SendGrid) or OTP (via Twilio) to confirm ownership of the contact method.
5. Customer enters the OTP or clicks the verification link, completing identity confirmation.
6. System creates the customer account, provisions a corresponding record in Salesforce CRM, and checks for any matching guest order history to link.
7. System sends a welcome notification via email and Firebase Cloud Messaging push, and logs the customer into an authenticated session.
8. Customer is redirected to a lightweight profile-completion prompt (optional fields) before landing on the homepage.

Alternate/Exception Flow — Failed Login and Account Lockout:

1. Returning customer enters email/mobile and password on the login screen.
2. System validates credentials against stored hashed password; validation fails.
3. System increments the failed-attempt counter for the account and IP address.
4. If the failed-attempt count reaches 5 within a 10-minute window, the system locks the account for 15 minutes and sends a lockout notification email.
5. Customer may either wait for the cool-down period to elapse or initiate the "Forgot Password" recovery flow to regain immediate access.
6. Upon successful recovery or cool-down expiry, the failed-attempt counter resets and normal login is restored.

13. Assumptions

- Customers have access to a working email inbox or mobile number capable of receiving SMS at the time of registration.
- Google and Facebook OAuth services remain available and compliant with platform terms of service throughout the program.
- The Twilio SMS Gateway and SendGrid Email API contracts provide sufficient throughput capacity for peak sale event volumes.
- Existing customer accounts migrated from the legacy platform will be pre-validated and will not require re-registration.
- Regional regulatory requirements for OTP-based authentication in India, UAE, and Southeast Asia will not materially change during the program timeline.

- The Signifyd Fraud Detection Service can be integrated within the program timeline without significant custom development.

14. Constraints

- The module must be delivered within the ShopSphere Platform Modernization Program's FY2026 budget and timeline allocation.
- All PII handling must comply with data residency expectations for India, UAE, and Southeast Asia jurisdictions.
- Third-party OAuth providers (Google, Facebook) impose their own rate limits and API versioning constraints outside ShopSphere's control.
- Legacy mobile app versions with a minimum supported OS baseline must continue to function during the phased rollout, limiting use of newer device-level biometric APIs.

15. Dependencies

- SendGrid Email API must be configured with verified sender domains for transactional registration and password-reset emails.
- Twilio SMS Gateway account provisioning and local number/sender ID approval for India, UAE, and Southeast Asia markets.
- Salesforce CRM Customer 360 schema must support the new registration source and consent fields.
- Signifyd Fraud Detection Service integration must be completed and tuned before the account lockout and risk-based step-up features can go live.
- Firebase Cloud Messaging project configuration for welcome and security push notifications.
- Coordination with the Admin Dashboard BRD team to ensure no overlap with internal admin SSO scope.

16. Risks

Risk ID	Description	Likelihood	Impact	Mitigation
RISK-001	High registration abandonment persists if OTP or email delivery is delayed.	Medium	High	Implement multi-provider failover and monitor delivery SLAs with Twilio/SendGrid.
RISK-002	Bot-driven fake registrations inflate account counts and skew analytics.	Medium	Medium	Enforce Signifyd fraud screening and CAPTCHA on suspicious signup patterns.
RISK-003	Credential stuffing attacks lead to account takeovers during peak sale events.	Medium	High	Enforce rate limiting, lockout policy, and risk-based step-up MFA.
RISK-004	OAuth provider policy or API changes (Google/Facebook) disrupt social login availability.	Low	Medium	Maintain fallback to email/mobile login and monitor provider changelogs.
RISK-005	Data residency non-compliance in one or more operating regions.	Low	High	Engage Compliance & Security Officer early; region-specific data storage review.
RISK-006	Peak-event traffic (10x normal) causes registration/login service degradation.	Medium	High	Load testing and auto-scaling validation ahead of Diwali/Black Friday events.

17. Data Requirements

The module captures and stores customer identity and authentication data classified as PII, requiring encryption at rest (AES-256) and in transit (TLS 1.2+), with access restricted on a least-privilege basis. Authentication credentials (password hashes, OTP records) are retained only as long as operationally necessary; OTPs are purged immediately after expiry or use. Registered account data is retained for the lifetime of the account plus a regulatory retention period following closure, after which it is anonymized in accordance with company data retention policy.

Data Field	Description	Classification
Full Name	Customer's given and family name captured at signup	PII
Email Address	Primary contact and login identifier	PII
Mobile Number	Alternate login identifier and OTP delivery channel	PII
Password Hash	Bcrypt-hashed credential, never stored in plaintext	Sensitive/Confidential
OAuth Provider ID	Google/Facebook subject identifier for social login linkage	PII
Consent Flags	Marketing and communication opt-in/opt-out status	Compliance data

Session/Device Metadata	Device ID, IP address, login timestamp, geolocation	PII/Security data
-------------------------	---	-------------------

18. Integration Requirements

System	Purpose	Direction	Data Exchanged
SendGrid Email API	Send verification links, password reset emails, welcome messages	Outbound	Email address, templated content, tracking status
Twilio SMS Gateway	Deliver OTPs for registration, login step-up, and password reset	Outbound	Mobile number, OTP code, delivery status
Salesforce CRM	Create/update Customer 360 profile on registration and profile changes	Outbound	Name, contact details, consent flags, account source
Signifyd Fraud Detection Service	Screen new registrations and risky logins for fraud/bot signals	Bidirectional	Device fingerprint, IP, account metadata, risk score
Firebase Cloud Messaging (FCM)	Deliver welcome and account security push notifications	Outbound	Device token, notification payload

19. Reporting Requirements

- Daily registration funnel report showing drop-off by step (form entry, verification, completion) segmented by channel.
- Login success/failure rate dashboard, including lockout events and step-up authentication triggers.
- Fraud screening summary report showing accounts flagged, blocked, or manually reviewed by the Signifyd integration.
- OTP and email delivery performance report (delivery time, failure rate) by provider and region.
- Guest-to-registered account conversion report, tracking linked order volume.
- Weekly executive summary of new registrations, active sessions, and security incidents via Tableau.

20. Success Metrics

Metric	Target
Registration completion rate (started vs. completed)	≥ 75% within 6 months of launch
Reduction in registration abandonment vs. baseline	≥ 20% reduction
Login success rate (first attempt)	≥ 95%
Account takeover incident rate	≤ 0.05% of active accounts per quarter
OTP delivery success rate	≥ 99% within 5 seconds
Social login adoption rate	≥ 30% of new registrations within 12 months

21. Future Enhancements

- Biometric login (fingerprint/Face ID) support for mobile app once minimum OS baseline is raised.
- Passwordless authentication via magic links or WebAuthn passkeys.
- Progressive profiling to enrich customer profiles gradually across subsequent sessions rather than at signup.
- Adaptive risk-scoring model trained on ShopSphere's own historical fraud data, reducing dependency on third-party scoring alone.
- Single sign-on extension to loyalty program and third-party partner portals.

22. Glossary

Term	Definition
OTP	One-Time Password, a time-limited code used to verify identity or authorize an action.
PII	Personally Identifiable Information, data that can identify a specific individual.
KYC	Know Your Customer, identity verification processes (out of scope for this module).
B2C	Business-to-Consumer, the commercial model of the ShopSphere marketplace.
API	Application Programming Interface, used for system-to-system integration.

SLA	Service Level Agreement, a commitment defining expected service performance.
GMV	Gross Merchandise Value, the total value of goods sold through the platform.
MFA	Multi-Factor Authentication, verification using more than one independent credential.
Credential Stuffing	An automated attack using stolen username/password pairs to attempt unauthorized logins.
Guest Checkout	Completing a purchase without creating a registered account.
Session Token	A secure, time-bound identifier issued after authentication to maintain a logged-in state.

23. Appendix

Reference Documents:

- ShopSphere Platform Modernization Program Charter, FY2026
- BRD-EC-ADM-002 — Admin Dashboard Module (covers internal admin SSO)
- BRD-EC-CHK-003 — Checkout & Guest Order Module
- ShopSphere Enterprise Security Baseline Standard, v3.2

Revision History:

Version	Date	Author	Change Description
0.1	05-Dec-2025	Vikram Singh	Initial draft circulated for stakeholder review
0.9	22-Dec-2025	Vikram Singh	Incorporated feedback from UX, QA, and Compliance reviews
1.0	12-Jan-2026	Vikram Singh	Finalized and approved by Product Owner and Executive Sponsor